Asignatura	Datos del estudiante	Fecha
Hacking Ético y Análisis de Malware	Apellidos: Ortiz Barros	9/12/2025
	Nombre: Alisson Michelle	

Actividad. Análisis de malware

Objetivos

El objetivo de esta práctica es que el alumno construya un laboratorio de análisis de malware con el que manejar de forma segura las muestras. A lo largo del ejercicio pondrás en práctica los conocimientos teóricos sobre análisis básico de malware. Aprenderás también a manejar muestras reales de malware.

Es muy importante que el alumno tenga muchísima precaución cuando trabaje con la muestra, para evitar dañar ningún sistema. Estás trabajando con una muestra real de malware.

Pautas de elaboración

Instalar una máquina virtual Windows lo más verosímil posible desde https://www.microsoft.com/en-us/evalcenter/evaluate-windows-10-enterprise, para realizar un análisis dinámico de comportamiento. Debemos tener en cuenta que debe ser segura para evitar riesgos en nuestra infraestructura. Para ello, puedes seguir este procedimiento:

1. Preparar el entorno con todas las herramientas necesarias.
2. Realizar un snapshot de base.
3. 3Desactivar antivirus.
4. Introducir la muestra y, antes de ejecutarla, asegurar que la máquina anfitrión esté aislada.
5. Realizar otro snapshot (con la máquina encendida, para tener mayor fluidez en las iteraciones).

© Universidad Internacional de La Rioja (UNIR)

Asignatura	Datos del estudiante	Fecha
Hacking Ético y Análisis de Malware	Apellidos: Ortiz Barros	9/12/2025
	Nombre: Alisson Michelle	

Atención: no introduzcas ningún dato personal que pueda quedarse grabado en la máquina y sea recuperable por el malware.

Para realizar el análisis dinámico y responder a las preguntas de la actividad se recomienda usar las siguientes herramientas, aunque el alumno si lo considera puede usar otras:

- Pafish.
- Process Explorer o Process Hacker.
- Procmon.
- Autoruns.
- Regshot .
- Bintext .
- Peid o Exeingo P>E.
- Inetsim o fake DNS o Fake-net.
- Wireshark.

Descargar la muestra HASH.zip (todo) y realiza el método de análisis básico y de comportamiento conforme a la siguiente figura:

© Universidad Internacional de La Rioja (UNIR)

Asignatura	Datos del estudiante	Fecha
Hacking Ético y Análisis de Malware	Apellidos: Ortiz Barros	9/12/2025
	Nombre: Alisson Michelle	

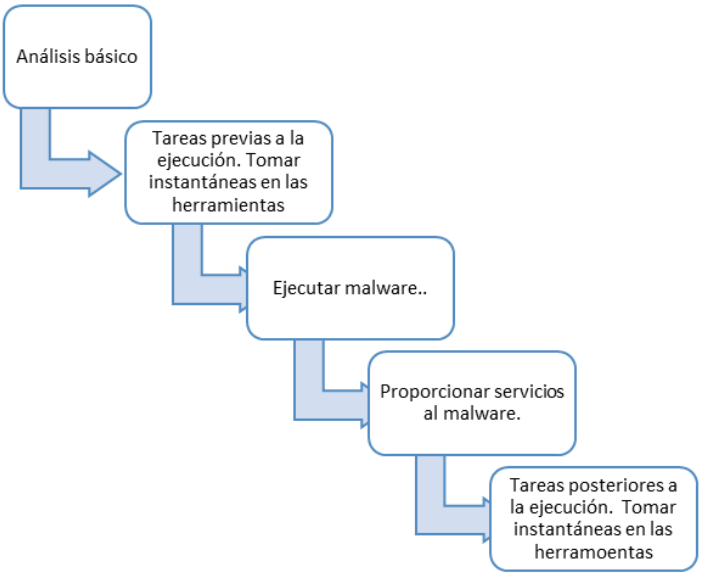
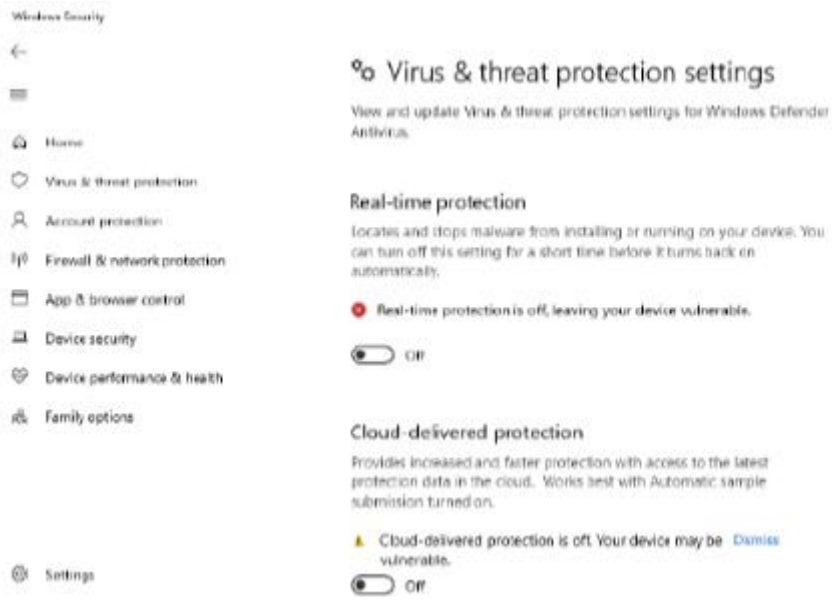


Figura 1. Método de análisis de comportamiento.

Sobre todo, analizar en el análisis de comportamiento:

- Operaciones sobre disco.
- Operaciones sobre procesos.
- Operaciones sobre registro.
- Operaciones de red.



© Universidad Internacional de La Rioja (UNIR)

Asignatura	Datos del estudiante	Fecha
Hacking Ético y Análisis de Malware	Apellidos: Ortiz Barros	9/12/2025
	Nombre: Alisson Michelle	

Responder a las siguientes preguntas:

1. Verificar con pafish la verosimilitud del entorno. ¿Qué concluyes de los resultados arrojados?

   En una verificación para el entorno virtual se utilizó la herramienta pafish, la cual detecta la presencia de máquinas virtuales, sandboxes lo que es un entorno de análisis. En cual los resultados se llevaron a cabo por múltiples pruebas en la detección de los hipervisores mediante CPUID, también la comprobación de configuraciones de sandboxes y la actividad del ratón. La detección del hipervisor y el número de procesadores indica la presencia de un entorno virtual la cual es (Fasc64), lo que arroja en el análisis deseado en la máquina virtual en las demás pruebas dan una verificación del tiempo de actividad del sistema operativo es decir no arrojan resultados definitivos. Lo que arrojó un resultado verosímil para el análisis del malware, para pafish se confirma que no se trata de sandbox genérica, las configuraciones son coherentes en el entorno de virtualización controlado y seguro esto garantiza que se realice en un entorno aislado y confiable para minimizar la detección de malware.

© Universidad Internacional de La Rioja (UNIR)

```
[*] Using IsDebuggerPresent() ... OK
[*] Using BeingDebugged via PEB access ... OK

[-] CPU information based detections
[*] Checking the difference between CPU timestamp counters (rdtsc) ... OK
[*] Checking the difference between CPU timestamp counters (rdtsc) forcing VM exit ... traced!
[*] Checking hypervisor bit in cpuid feature bits ... traced!
[*] Checking cpuid hypervisor vendor for known VM vendors ... traced!

[-] Generic reverse turing tests
[*] Checking mouse presence ... OK
[*] Checking mouse movement ... OK
[*] Checking mouse speed ... OK
[*] Checking mouse click activity ... traced!
[*] Checking mouse double click activity ... traced!
[*] Checking dialog confirmation ... traced!
[*] Checking plausible dialog confirmation ... traced!

[-] Generic sandbox detection
[*] Checking username ... OK
[*] Checking file path ... OK
[*] Checking common sample names in drives root ... OK
[*] Checking if disk size <= 60GB via DeviceIoControl() ... OK
[*] Checking if disk size <= 60GB via GetDiskFreeSpaceExA() ... traced!
[*] Checking if sleep() is patched using GetTickCount() ... OK
[*] Checking if NumberOfProcessors is < 2 via PEB access ... traced!
[*] Checking if NumberOfProcessors is < 2 via GetSystemInfo() ... traced!
[*] Checking if physical memory is < 1Gb ... OK
[*] Checking operating system uptime using GetTickCount() ... traced!
[*] Checking if operating system IsNativeVhdBoot() ... OK

[-] Sandboxie detection
[*] Using GetModuleHandle(sbiedll.dll) ... OK

[-] Wine detection
[*] Using GetProcAddress(wine_get_unix_file_name) from kernel32.dll ... OK
```

```
[*] Reg key (HKCU\SOFTWARE\Wine) ... OK

[-] VirtualBox detection
[*] Scsi port->bus->target id->logical unit id-> 0 identifier ... OK
[*] Reg key (HKLM\HARDWARE\Description\System "SystemBiosVersion") ... traced!
[*] Reg key (HKLM\SOFTWARE\Oracle\VirtualBox Guest Additions) ... traced!
[*] Reg key (HKLM\HARDWARE\Description\System "VideoBiosVersion") ... traced!
[*] Reg key (HKLM\HARDWARE\ACPI\DSDT\VBOX__) ... traced!
[*] Reg key (HKLM\HARDWARE\ACPI\FADT\VBOX__) ... traced!
[*] Reg key (HKLM\HARDWARE\ACPI\RSDT\VBOX__) ... traced!
[*] Reg key (HKLM\SYSTEM\ControlSet001\Services\VBox*) ... traced!
[*] Reg key (HKLM\HARDWARE\DESCRIPTION\System "SystemBiosDate") ... traced!
[*] Driver files in C:\WINDOWS\system32\drivers\VBox* ... traced!
[*] Additional system files ... traced!
[*] Looking for a MAC address starting with 08:00:27 ... traced!
[*] Looking for pseudo devices ... traced!
[*] Looking for VBoxTray windows ... traced!
[*] Looking for VBox network share ... traced!
[*] Looking for VBox processes (vboxservice.exe, vboxtray.exe) ... traced!
[*] Looking for VBox devices using WMI ... traced!

[-] VMware detection
[*] Scsi port 0,1,2 ->bus->target id->logical unit id-> 0 identifier ... OK
[*] Reg key (HKLM\SOFTWARE\VMware, Inc.\VMware Tools) ... OK
[*] Looking for C:\WINDOWS\system32\drivers\vmmouse.sys ... OK
[*] Looking for C:\WINDOWS\system32\drivers\vmhgfs.sys ... OK
[*] Looking for a MAC address starting with 00:05:69, 00:0C:29, 00:1C:14 or 00:50:56 ... OK
[*] Looking for network adapter name ... OK
[*] Looking for pseudo devices ... OK
[*] Looking for VMware serial number ... OK

[-] Qemu detection
[*] Scsi port->bus->target id->logical unit id-> 0 identifier ... OK
[*] Reg key (HKLM\HARDWARE\Description\System "SystemBiosVersion") ... OK
[*] cpuid CPU brand string `QEMU Virtual CPU` ... OK
```

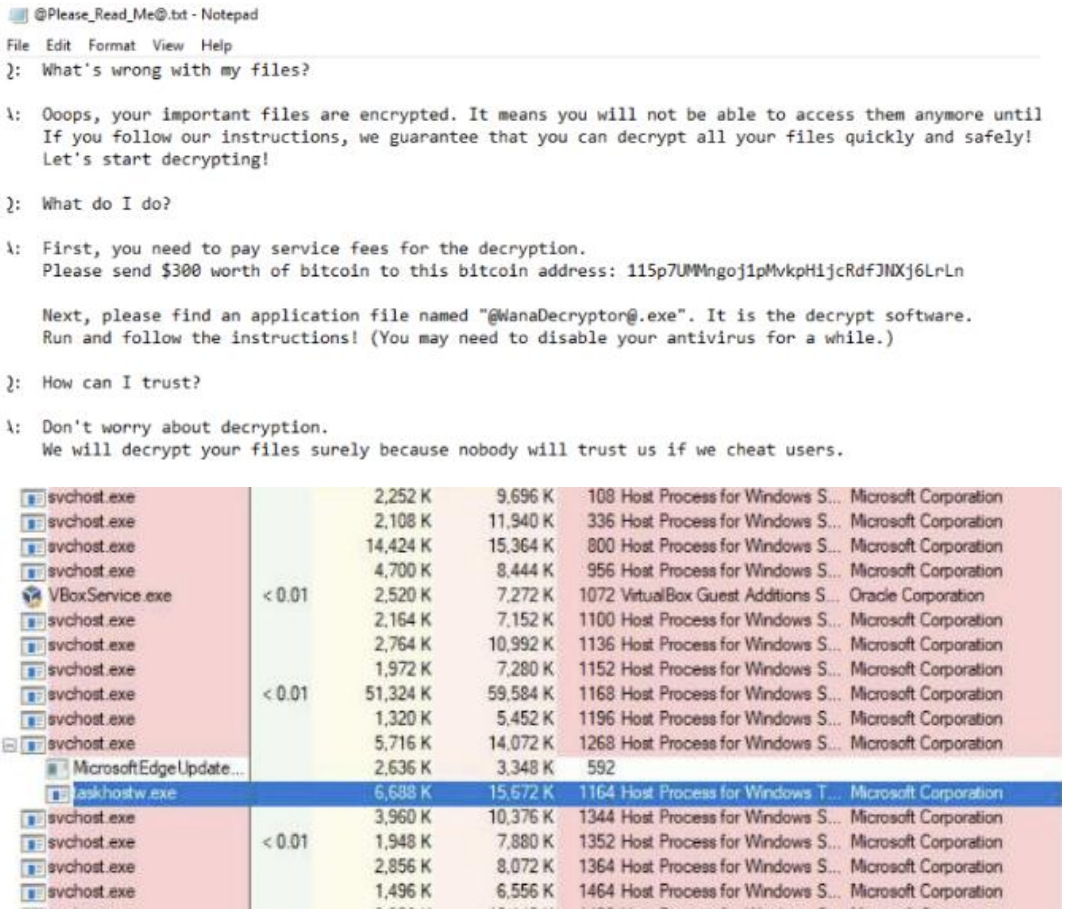
2. Realizar un análisis de cadenas y comentar las más importantes.

   En las cadenas importantes encontradas se vio que, al infectar el sistema, WannaCry implementa un mecanismo de tiempo de respuesta que establece dos períodos críticos: el incremento tarifario del rescate tras un intervalo de cuatro días y la destrucción definitiva de la información después de siete días. Este *ransomware* permite la configuración flexible de la suma de extorsión, aceptando

© Universidad Internacional de La Rioja (UNIR)

el pago en dólares o en la criptomoneda Bitcoin. El análisis forense reveló la existencia de cepas de WannaCry que demandaban equivalentes de 300 USD y 600 USD pagaderos en Bitcoin. La dirección de billetera de Bitcoin se especifica primordialmente en el archivo de configuración del *malware*; sin embargo, si este componente no se localiza, se activa una dirección de respaldo incrustada en el código fuente. La labor de identificar y registrar las diversas direcciones de Bitcoin asociadas a las campañas de WannaCry ha facilitado el seguimiento y la trazabilidad de las transacciones financieras vinculadas a este ciberataque.

En cambio, en las URLs de Bitcoin, WannaCry muestra direcciones de billeteras Bitcoin en pago del rescate como se muestra en la siguiente imagen:



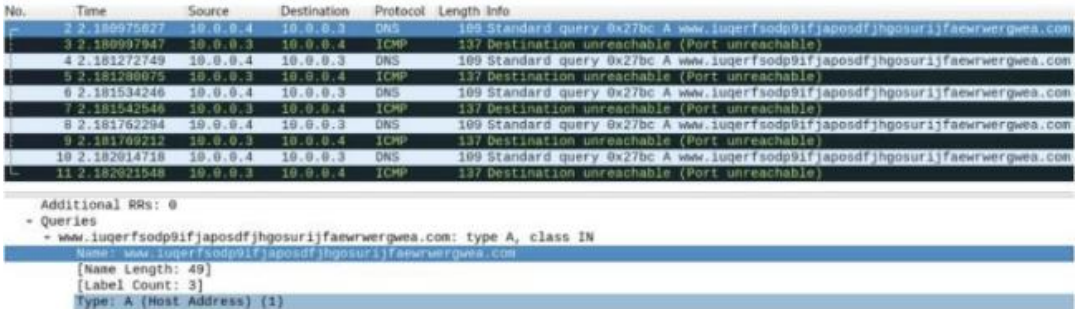
3. Obtener los indicadores de peligrosidad del malware.

   Se puede cifrar los archivos con las siguientes extensiones específicas que son se muestran en la siguiente imagen:

© Universidad Internacional de La Rioja (UNIR)

```
der .pfx .key .crt .csr .p12 .pem .odt .ott .sxw .stw .uot .3ds .max .3dm .ods .ots
sxc .stc .dif .slk .wb2 .odp .otp .sxd .std .uop .odg .otg .sxm .mml .lay .lay6 .asc
sqlite3 .sqlitedb .sql .accdb .mdb .dbf .odb .frm .myd .myi .ibd .mdf .ldf .sln .suo
cpp .pas .asm .cmd .bat .ps1 .vbs .dip .dch .sch .brd .jsp .php .asp .java .jar
class .mp3 .wav .swf .fla .wmv .mpg .vob .mpeg .asf .avi .mov .mp4 .3gp .mkv .3g2
flv .wma .mid .m3u .m4u .djvu .svg .psd .nef .tiff .tif .cgm .raw .gif .png .bmp .jpg
jpeg .vcd .iso .backup .zip .rar .tgz .tar .bak .tbk .bz2 .PAQ .ARC .aes .gpg .vmx
vmdk .vdi .sldm .sldx .sti .sxi .602 .hwp .snt .onetoc2 .dwg .pdf .wk1 .wks .123 .rtf
csv .txt .vsdx .vsd .edb .eml .msg .ost .pst .potm .potx .ppam .ppsx .ppsm .pps .pot
pptm .pptx .ppt .xltm .xltx .xlc .xlm .xlt .xlw .xlsb .xlsm .xlsx .xls .dotx .dotm
dot .docm .docb .docx .doc
```

En la propagación por red el exploit EternalBlue para através del SMB como se muestra la imagen:



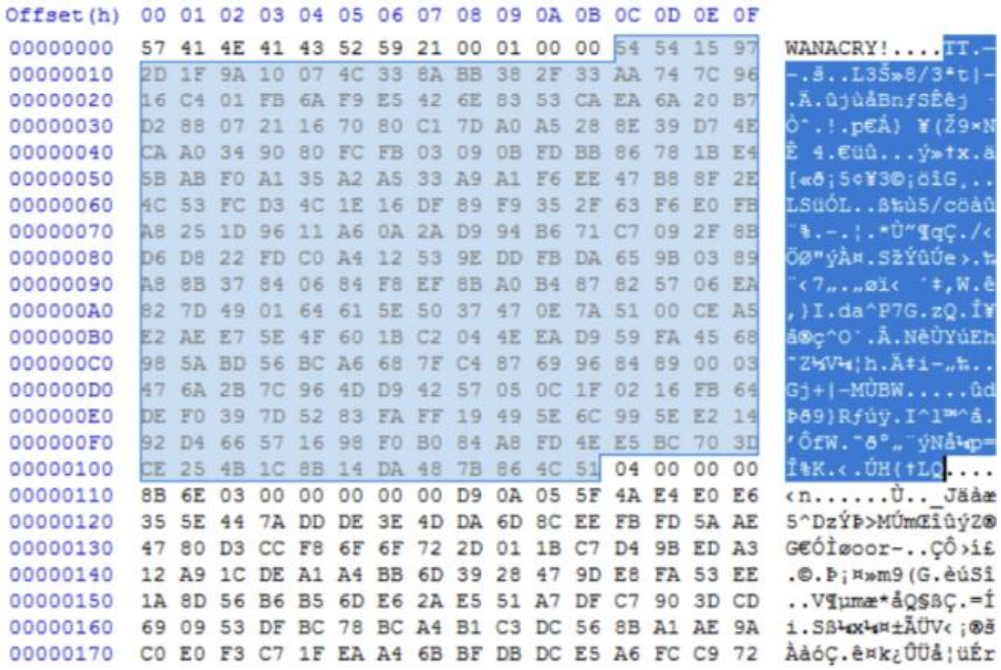
4. ¿La muestra hace uso de alguna tecnología de ofuscación?

WannaCry establece un sofisticado proceso de cifrado por víctima basado en la criptografía híbrida. Para cada infección, genera un par único de claves RSA-2048, guardado localmente con la extensión .eky. La clave privada RSA se protege cifrándola con una clave pública RSA que ya está integrada en el malware. Este par de claves RSA se utiliza luego para cifrar una clave AES-128 aleatoria, que es la clave maestra usada para el cifrado real de cada archivo.

El cifrado se realiza leyendo y procesando el archivo en memoria, escribiendo después un archivo cifrado temporal con un nombre como [número aleatorio].WNCRYT. Una vez finalizado, este archivo temporal se renombra a su nombre original más la extensión .WNCRY y se mueve a su ubicación inicial. Un proceso auxiliar (taskdl.exe) se encarga de borrar los archivos temporales. Es relevante señalar que el proceso de cifrado no sobrescribe los datos originales, lo cual podría permitir la recuperación forense bajo ciertas condiciones. No obstante, el contenido completo de cada archivo queda cifrado y marcado con un encabezado único, volviendo los datos inaccesibles sin la clave adecuada.

© Universidad Internacional de La Rioja (UNIR)

El cifrado de cadenas para el empaquetado del binario como se muestra en la siguiente imagen:



5. Análisis de las API de Windows ¿Qué dos DLL destacarías?

El éxito del cifrado de WannaCry depende de dos bibliotecas cruciales del sistema Windows, ambas partes de la CryptoAPI:

1. Cryptsp.dll: Esta librería es fundamental ya que facilita las funciones de cifrados centrales. WannaCry la emplea para:

- Iniciar y finalizar sesiones criptográficas usando funciones como $CryptAcquireContext$ y $CryptReleaseContext$.
- Generar las claves de cifrado (RSA y AES) a través de $CryptGenKey$.
- Cifrar los archivos de las víctimas mediante la función $CryptEncrypt$.

2. Cryptbase.dll: Esta DLL actúa como un complemento de bajo nivel. WannaCry la utiliza para gestionar de manera efectiva las claves RSA y AES, empleando funciones como $CryptImportKey$ y $CryptExportKey$. Estas funciones son esenciales para que el ransomware pueda intercambiar y manejar las claves criptográficas, garantizando que el proceso de cifrado sea robusto y que los archivos permanezcan inaccesibles sin la clave de descifrado correcta.

© Universidad Internacional de La Rioja (UNIR)

```
tasksche.exe pid:   2808
Command line :
 C:\ProgramData\zmlrzffkezkivj575\tasksche.exe
Service Pack 1

Path
----
C:\ProgramData\zmlrzffkezkivj575\tasksche.exe
C:\Windows\SYSTEM32\ntdll.dll
C:\Windows\system32\kernel32.dll
C:\Windows\system32\KERNELBASE.dll
C:\Windows\system32\USER32.dll
C:\Windows\system32\GDI32.dll
C:\Windows\system32\LPK.dll
C:\Windows\system32\USP10.dll
C:\Windows\system32\msvcrt.dll
C:\Windows\system32\ADVAPI32.dll
C:\Windows\SYSTEM32\sechost.dll
C:\Windows\system32\RPCRT4.dll
C:\Windows\system32\IMM32.DLL
C:\Windows\system32\MSCTF.dll
C:\Windows\system32\apphelp.dll
C:\Windows\system32\CRYPTSP.dll
C:\Windows\system32\rsaenh.dll
C:\Windows\system32\CRYPTBASE.dll
C:\Windows\system32\SHELL32.dll
C:\Windows\system32\SHLWAPI.dll
C:\Windows\system32\MSVCP60.dll
C:\Windows\system32\ntmarta.dll
C:\Windows\system32\WLDAP32.dll
C:\Windows\system32\ole32.dll
C:\Windows\system32\SspiCli.dll
```

6. ¿Dónde se instala el programa el programa malicioso?

   Se instala en C:\WINDOWS\ o C:\ProgramData\ con nombres como tasksche.exe

7. ¿Cuál es el nombre original del malware y cuál es el que suplanta?

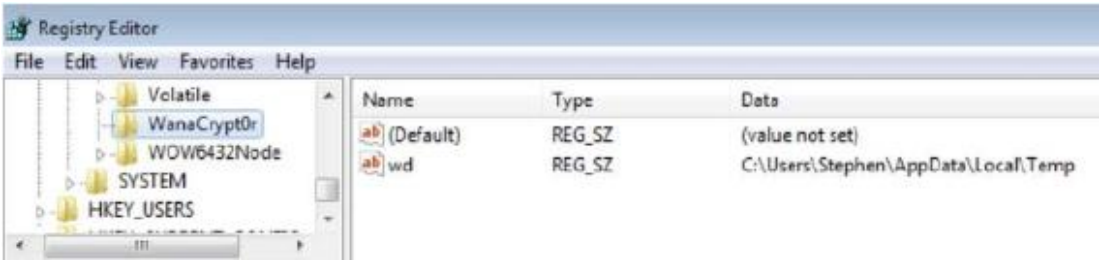
   - El nombre original es tasksche.exe
   - WannaCry puede utilizar nombres de archivos legítimos y camuflarse como svchost.exe.

© Universidad Internacional de La Rioja (UNIR)

8. ¿Modifica algún registro?

   WannaCry asegura su persistencia modificando el registro de Windows, específicamente al crear entradas en la ruta HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows\CurrentVersion\Run. Esto garantiza que la ejecución del malware persista tras reinicios o inicios de sesión.

   Además, el ransomware almacena su directorio de trabajo actual en una clave de registro bajo \SOFTWARE\WanaCrypt0r. Si WannaCry se está ejecutando con permisos de administrador (privilegios elevados), esta clave se registra en el subárbol HKLM (HKEY_LOCAL_MACHINE). La creación de esta entrada de ejecución en el registro también tiene el propósito de asegurar que la interfaz gráfica del ransomware se muestre inmediatamente a la víctima cada vez que el sistema se inicie o reinicie.



9. ¿Cómo se llama el proceso iniciado por el malware?

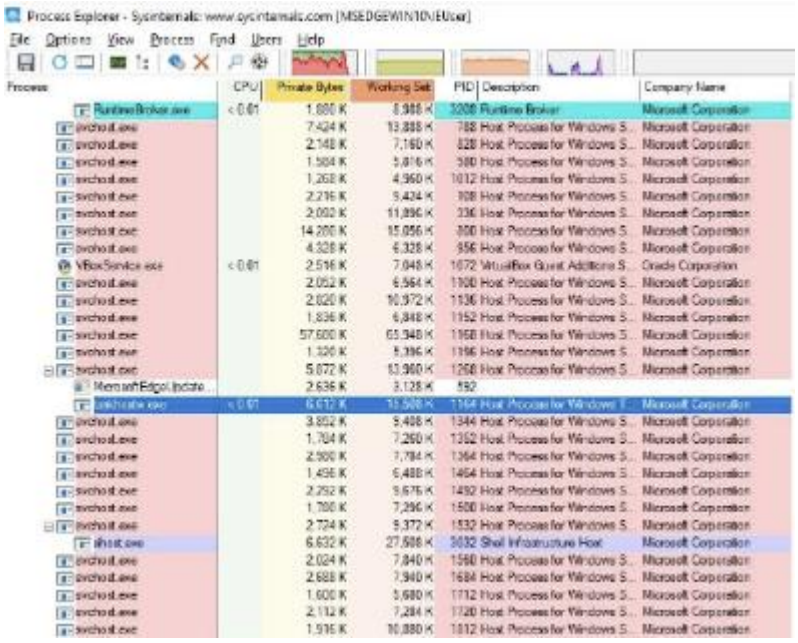
   tasksche.exe

10. ¿Qué diferencia hay entre las cadenas del proceso del malware en memoria con respecto a disco?

    Cuando WannaCry reside en el disco, sus elementos textuales pueden encontrarse en un **estado ofuscado o cifrado** para evadir la detección. Sin embargo, durante la ejecución activa, estas mismas cadenas son **desofuscadas o descifradas** automáticamente en la memoria para que el *malware* pueda utilizarlas.

© Universidad Internacional de La Rioja (UNIR)

Asignatura	Datos del estudiante	Fecha
Hacking Ético y Análisis de Malware	Apellidos: Ortiz Barros	9/12/2025
	Nombre: Alisson Michelle	



11. ¿Que mutex crea el malware?

Crea un mutex llamado MsWinZonesCacheCounterMutexA es para evitar ejecuciones con la misma máquina.

12. ¿Qué aproximación seguirías si necesitases analizar el código?

El proceso de análisis de código implica las siguientes tareas clave:

- Depuración: Utilizar x64dbg para rastrear paso a paso la ejecución del código.
- Ingeniería Inversa: Emplear IDA Pro o Ghidra para desensamblar el binario y descifrar su lógica interna.
- Monitoreo del Sistema: Capturar las interacciones con el sistema operativo (llamadas a la API) usando Process Monitor.
- Análisis de Conexión: Inspeccionar la comunicación de red con la herramienta Wireshark.

13. ¿Crea o modifica algún archivo?

Como parte de su operación, el ransomware deja dos tipos principales de archivos:

- Los archivos de datos de las víctimas, que son cifrados y modificados para llevar la extensión .WNCRYT.

© Universidad Internacional de La Rioja (UNIR)

- La nota de extorsión, necesaria para comunicarse con la víctima, identificada como @Please_Read_Me@.txt.

14. ¿Qué acciones realiza el malware en la máquina víctima?

- Cifrado: Utiliza un sistema RSA/AES híbrido. Se apoya en la CryptoAPI para RSA y generación de claves, y tiene su propia implementación de AES.
- Alcance: Enumera y ataca todos los discos asignados (locales, extraíbles, de red), excluyendo recursos de red no mapeados.
- Mecanismo Anti-Análisis: Comprueba la existencia de la exclusión mutua ($Global\MsWinZonesCacheCounterMutexA$); si está presente, el malware finaliza su proceso.
- Objetivos: Prioriza archivos de productividad, bases de datos y multimedia. Evita el cifrado en rutas que contienen directorios o idiomas específicos, mostrando un enfoque selectivo y sofisticado para maximizar el impacto.

15. ¿Serías capaz de extraer algún IOC característico y relevante?

Describir todo el proceso de análisis estático básico y de comportamiento, incluyendo evidencias, como capturas de pantalla (relevantes y con la calidad mínima necesaria para ampliarse), textos generados por las aplicaciones, etc. Se valorará cualquier información adicional que el alumno pueda aportar de su análisis: discusión de los resultados y conclusiones.

Indicador de Compromiso (IOC)	**Tipo de Artefacto**	**Valor/Ejemplo Específico**
Hash del Ejecutable	Identificador de Archivo (SHA-256)	$24d004a104d4d54034dbcffc2a4b19a11f39008a575aa614ea04703480b1022c$
Dirección Bitcoin	Destino de Rescate	$1Mz7153HMuxXTuR2R1t78mGSdzaAtNbBWX$
Mutex	Objeto de Sincronización Local	$MsWinZonesCacheCounterMutexA$

© Universidad Internacional de La Rioja (UNIR)

Dominio C2	Infraestructura de Red (Kill Switch)	$www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com$

Conclusiones:

- El análisis exhaustivo de WannaCry confirmó su sofisticación operativa, impulsada por un ataque híbrido de cifrado RSA y AES que, al aprovechar la CryptoAPI de Windows, hace que los datos de las víctimas sean casi imposibles de recuperar.
- El malware exhibe una ejecución selectiva, cifrando discos mapeados (locales y de red) mientras evita ciertas configuraciones del sistema, y utiliza la exclusión mutua ($Global\MsWinZonesCacheCounterMutexA$) como un mecanismo de evasión y control para frustrar el análisis y evitar auto-infecciones.
- Su propagación masiva se debió a la explotación de la vulnerabilidad EternalBlue en el protocolo SMB, lo que le permitió comprometer miles de sistemas globalmente en muy poco tiempo.
- En retrospectiva, WannaCry es un caso de estudio fundamental que combina técnicas avanzadas de cifrado, propagación y evasión. Sirve como un poderoso recordatorio de que la aplicación oportuna de parches y el fortalecimiento continuo de las defensas son esenciales para contrarrestar ransomware de esta magnitud y prevenir futuras amenazas.

Referencias:

Check Point Research. (2017). WannaCry ransomware: What you need to know. Recuperado de https://research.checkpoint.com

Elastic Blog. (2017). WCry/WanaCry ransomware technical analysis. Recuperado de https://www.elastic.co/blog/wcrywanacry-ransomware-technical-analysis (Fuente

© Universidad Internacional de La Rioja (UNIR)

útil para detalles como la importación de claves criptográficas y el proceso de cifrado).

Kaspersky Lab. (2017). Ransomware WannaCry: All you need to know. Recuperado de https://www.kaspersky.com/resource-center/threats/ransomware-wannacry

Symantec Security Response. (2017). WannaCry: Ransomware attacks show strong links to Lazarus group. Recuperado de https://www.symantec.com/blogs/threat-intelligence/wannacry-ransomware-attack

CISA (Cybersecurity and Infrastructure Security Agency). (2017). Alert (TA17-132A): Indicators Associated With WannaCry Ransomware. Recuperado de https://www.cisa.gov/news-events/alerts/2017/05/12/indicators-associated-wannacry-ransomware

Europol. (2017). Wannacry Ransomware. Recuperado de https://www.europol.europa.eu/wannacry-ransomware

Microsoft Security Team. (2017). WannaCrypt ransomware worm targets out-of-date systems. Recuperado de https://www.microsoft.com/security/blog/2017/05/12/wannacrypt-ransomware-worm-targets-out-of-date-systems/

National Audit Office (NAO). (2017). Investigation: WannaCry cyber attack and the NHS. Recuperado de https://www.nao.org.uk/wp-content/uploads/2017/10/Investigation-WannaCry-cyber-attack-and-the-NHS.pdf

© Universidad Internacional de La Rioja (UNIR)

Asignatura	Datos del estudiante	Fecha
Hacking Ético y Análisis de Malware	Apellidos: Ortiz Barros	9/12/2025
	Nombre: Alisson Michelle	

Extensión y formato

La memoria (que se entregará en formato PDF) debe tener una extensión máxima de 20 páginas, excluyendo portada, índice y referencias. Puedes utilizar este archivo como plantilla para referencia del formato (fuente, interlineado, etc.)

El formato de las referencias debe ser APA.

Rúbrica

Título de la actividad	Descripción	Puntuación máxima (puntos)	Peso %
Criterio 1	Calidad de la memoria	1	10%
Criterio 2	Creación y documentación del laboratorio	1,5	15%
Criterio 3	Documentación del análisis dinámico básico	1,5	15%
Criterio 4	Respuestas (4% por respuesta)	6	60%

© Universidad Internacional de La Rioja (UNIR)